

# LoadLead — Platform-Wide E2E Audit (v4)

**Date:** 2026-07-10 **Auditor:** Platform Engineering **Scope:** Full stack — backend business logic, frontend, live smoke, and cross-environment parity (dev / staging / prod). Ref commit `ee33702` (main). Prior rounds: v1 2026-06-25, v2/v3 2026-07-03/04.

## 1. Executive summary

This is the **healthiest audit result of the three rounds** — and the first with the SCRUM-59 compliance-documents surface (W-9/COI/LOA/shipper policy) in scope. All automated verification is green: **698/698 backend tests** (90 files, +68 tests vs v3), frontend typecheck/build clean, **46/46 Playwright E2E**, and — for the first time — **zero Terraform drift in both staging and prod**. The v3 HIGH env-parity defect (staging silently writing prod tables) is structurally closed: staging resolves all 49 config tables through one `DYNAMODB_TABLE_PREFIX`, the boot guard fails closed on any prod-name leak, and prod has **zero missing tables** (56 required, all present). The production frontend bundle is byte-identical to a fresh HEAD build, and the W-9 render self-check returns the *same content hash* on local, staging, and prod — deterministic renders across environments.

The risk profile has therefore shifted from *configuration/parity defects* (v2/v3) to **concurrency correctness and scale readiness**. The four HIGH findings this round are: (H1) an ACCEPTED negotiation can permanently lack its pinned shipper-policy snapshot after a transient error, with no repair job; (H2) the compliance-document supersede is an unconditional read-then-flip, so concurrent W-9 submits can leave two "current" versions; (H3) a cluster of full-table scans on request-hot paths (relationship resolution scans the *loads table on every packet/document open*) that will not survive beta scale-up; and (H4) the public W-9 render self-check endpoint — added 2026-07-09 by our own deploy-smoke work — is CPU-bound and has no rate limiting (only `/api/auth` is limited), making it a low-effort DoS vector. All four have small, well-bounded fixes (Section 6).

One process win worth institutionalizing: the authenticated staging W-9 E2E run on 2026-07-09 caught a template-packaging bug that route-mount smoke had passed over for both environments. The lesson — *smoke must exercise the real path, not just the mount* — is now encoded in the deploy pipeline (render self-check) and should be extended to a scheduled synthetic (Section 7).

## 2. Scorecard

| Lane                       | Result | Detail                                                                                                                                                      |
|----------------------------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Backend unit/integration   | PASS   | 698/698, 90 files, 4.5s. One known-flaky test (fieldCrypto tamper — base64 padding-bit flip; passed this run; fix task open).                               |
| Frontend typecheck + build | PASS   | <code>tsc</code> clean; Vite build clean; <b>no react-vendor split</b> (the prod blank-page gotcha); single 413 KB vendor chunk.                            |
| Frontend E2E (Playwright)  | PASS   | 46/46 — hauler negotiation H1–H9 (incl. e-sign gate + window expiry), shipper S1–S5 (accept/counter/reject/live-update), public-route crawl, tour scoping.  |
| Prod FE = HEAD             | PASS   | Fresh build emits <code>index-CCI0eFp8.js</code> / <code>vendor-DfqDJZw7.js</code> — identical hashed names to the live prod bundle. No unshipped FE delta. |

|                             |                            |                                                                                                                                                                                                                                                                                                                         |
|-----------------------------|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Terraform drift — staging   | <b>CLEAN</b>               | <code>tofu plan</code> : No changes.                                                                                                                                                                                                                                                                                    |
| Terraform drift — prod      | <b>CLEAN</b>               | <code>tofu plan</code> : No changes (first fully-clean prod plan; worm-sink .DS_Store drift fixed in PR #53).                                                                                                                                                                                                           |
| Terraform — dev             | <b>N/A — never applied</b> | Plan fails on unset required variables; <b>0</b> <code>LoadLead-Dev-*</code> tables and no dev EB env exist in AWS. Dev is local-DynamoDB in practice (L4).                                                                                                                                                             |
| Table parity                | <b>PASS</b>                | Parity script green (staging via prefix + 10 service overrides; dev via explicit list). Prod: 56 required tables, <b>0 missing</b> , 1 true orphan ( <code>LoadLead_AdminAudit</code> , L1).                                                                                                                            |
| EB config parity            | <b>PASS</b>                | Only intentional diffs: prod <code>BETA_MODE=true</code> (private-beta wall) / staging <code>off</code> ; staging opts in <code>KMS_MODE=live</code> + persona flag; prod forces KMS live via <code>APP_ENV</code> lock.                                                                                                |
| Live smoke — prod + staging | <b>PASS</b>                | Health + <code>productionHardened:true</code> ; guards 401; beta gate 403<br><code>BETA_REQUIRED</code> (structured, fail-closed); <code>/_test</code> absent in prod; SPA fallback 200 on deep routes; <code>index.html</code> no-cache / assets immutable; W-9 render-check hash identical across local/staging/prod. |

### 3. Environment parity matrix

| Dimension              | Dev                                                                                    | Staging                                                                     | Prod                                            | Verdict                                  |
|------------------------|----------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|-------------------------------------------------|------------------------------------------|
| Exists in AWS          | No (paper stack)                                                                       | Yes (pausable)                                                              | Yes                                             | <b>L4: decide dev's fate</b>             |
| Table namespace        | local / <code>LoadLead-Dev-</code> (unapplied)                                         | <code>DYNAMODB_TABLE_PREFIX=LoadLead-Staging-</code> + 10 service overrides | <code>LoadLead_*</code> defaults (no overrides) | <b>Fail-closed via boot guard</b>        |
| Env-var payload        | —                                                                                      | 1,511 chars (was >4096 pre-fix)                                             | well under cap                                  | <b>EB 4096 blocker closed</b>            |
| KMS (W-9 TIN)          | local stub                                                                             | live, key <code>21e98dbe...</code>                                          | live (forced), key <code>ee357d04...</code>     | <b>Per-env keys, least-privilege IAM</b> |
| Compliance S3          | —                                                                                      | SSE+versioning+private                                                      | + Object Lock + deny-deletes                    | <b>Prod strictly stronger</b>            |
| Beta gate              | —                                                                                      | off (full-app mirror)                                                       | on (waitlist wall)                              | <b>Intentional</b>                       |
| Fleet-carrier persona  | —                                                                                      | enabled (validation)                                                        | muted (default)                                 | <b>Intentional</b>                       |
| W-9 render determinism | <code>contentHash f9e4c415...</code> identical on local, staging, prod (241,615 bytes) |                                                                             |                                                 | <b>Deterministic</b>                     |

### 4. Findings register

Each finding is tagged verified (reproduced/confirmed in code or live by the auditor) or agent (reported by a read-only audit agent with file:line evidence; spot-checks passed but not independently reproduced).

## HIGH

| ID                          | Finding                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Failure scenario                                                                                                                                                                                                                                                    |
|-----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| H1<br><span>verified</span> | <b>ACCEPTED negotiation can permanently lack its policy snapshot.</b> <code>negotiationService.ts:539–545</code> : after the terminal ACCEPTED transition, <code>snapshotPolicyOntoLoad()</code> failures that are not <code>AppError</code> are logged and swallowed; assignment proceeds. No retry, no repair sweeper.                                                                                                                                                                                   | DynamoDB throttle or network blip during accept → binding assignment exists with no pinned policy version; settlement/compliance review later finds no policy evidence for the load. Silent, permanent.                                                             |
| H2<br><span>verified</span> | <b>Compliance supersede race — two "current" documents.</b> <code>complianceDocumentService.ts</code> flips the prior current version with an unconditional read-then-update (zero <code>ConditionExpression</code> s in the file). Concurrent submits for the same owner+type can both land as <code>isCurrentVersion=true</code> .                                                                                                                                                                       | Hauler double-clicks submit / retries during a slow response → two current W-9s. <code>getCurrent()</code> papers over it by newest- <code>createdAt</code> sort, so the corruption is invisible until an audit counts currents.                                    |
| H3<br><span>verified</span> | <b>Scan-at-scale cluster on request-hot paths.</b> (a) <code>relationshipResolver.gatherFacts()</code> <i>scans the entire loads table on every compliance packet/document open</i> ; (b) <code>accessorialChargeService.listForLoad()</code> scans the charges table per load-detail view; (c) <code>negotiationService.negsForLoad()</code> silently falls back to a full scan if its GSI is missing — under 1s long-polling. Repo convention (scan-all + filter) is fine at beta size, lethal at scale. | Loads table at 100k+: every packet open is a full scan; concurrent shipper traffic exhausts RCU → throttling cascades to unrelated endpoints. The GSI fallback turns an infra mistake into a self-DoS that "works" — nobody notices until the bill or the brownout. |
| H4<br><span>verified</span> | <b>Public CPU-bound endpoint with no rate limit.</b> <code>GET /api/compliance/w9/render-check</code> (added 2026-07-09 for deploy smoke — by us) renders a full PDF per request, unauthenticated. The only rate limiter in the app guards <code>/api/auth</code> .                                                                                                                                                                                                                                        | A loop of cheap GETs pins the single-instance backend on pdf-lib renders; health checks slow; EB flaps. Trivial to script, no auth needed.                                                                                                                          |

## MEDIUM

| ID                          | Finding                                                                                                                                                                                                                         | Failure scenario                                                                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M1<br><span>verified</span> | <b>Full TIN retained in frontend state after W-9 submit.</b> <code>OwnerOperatorCompliance.tsx</code> : on success the form state (incl. <code>f.tin</code> ) is never cleared; the SSN/EIN stays in the input and React state. | Shoulder-surf / screen-share / screenshot after submit exposes the full SSN. Violates the platform's own "masked except gated view" rule on the client side. |
| M2<br><span>verified</span> | <b>Policy-sign card has no 409/410 UX.</b> <code>LoadPolicySignCard.tsx:39–54</code> : all errors collapse to <code>toast.error(e.message)</code> — version-conflict (policy updated)                                           | Shipper edits policy mid-flight → hauler's sign 409s with a cryptic toast; hauler doesn't know a                                                             |

|                       |                                                                                                                                                                                                                                                                  |                                                                                                                                                              |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                       | and gone (attachment removed) are indistinguishable from network noise.                                                                                                                                                                                          | refresh shows v2; load sits unsigned.                                                                                                                        |
| <b>M3</b><br>verified | <b>COIs never auto-expire.</b> <code>coiService.expireDueCois()</code> exists and is tested, but nothing invokes it — no cron, route, or boot hook.                                                                                                              | Insurance lapses; the VERIFIED badge persists indefinitely; a shipper books a hauler whose COI expired months ago. Trust-critical for a freight marketplace. |
| <b>M4</b><br>verified | <b>No global 401 interceptor; widespread silent catches.</b> <code>lib/api.ts</code> throws on <code>!ok</code> ; many callers <code>.catch(() =&gt; {})</code> . Session expiry mid-action is swallowed.                                                        | Expired session + "Accept bid" → nothing happens, no toast, no redirect; user retries confused; state ambiguity on money-affecting actions.                  |
| <b>M5</b><br>agent    | <b>Stale load header after negotiation accept.</b> <code>NegotiationPanel</code> fires <code>onAssigned()</code> but shipper <code>LoadDetail</code> doesn't refetch the load — header rate/status can contradict the panel.                                     | Accepted at \$2.50/mi; header still shows posted \$3.00/mi until reload — conflicting money info on one screen.                                              |
| <b>M6</b><br>agent    | <b>Funding advance not reconciled against later charge transitions.</b> Advance pins <code>chargeStatus='APPROVED'</code> at issue; the charge can later become DISPUTED/ADJUSTED with no linkage or alert on the advance.                                       | Charge disputed after funds advanced → reconciliation must catch it manually or funds leak on recourse.                                                      |
| <b>M7</b><br>agent    | <b>Counterparty notifications are fire-and-forget.</b> <code>routes/negotiations.ts</code> <code>notify()</code> swallows all send failures — no retry, no dead-letter.                                                                                          | Push outage during assignment → driver never told; pickup window missed; no operational signal anything failed.                                              |
| <b>M8</b><br>agent    | <b>Runtime-config gate is sticky on fetch failure.</b> <code>RuntimeConfigContext</code> fails closed (persona off) but marks <code>loaded:true</code> with no retry — a transient failure pins a CARRIER_ADMIN on the "unavailable" page for the whole session. | One dropped request at app boot → legitimate carrier locked out until hard refresh.                                                                          |
| <b>M9</b><br>agent    | <b>Charge history <code>amountCentsAfter</code> ambiguous under <code>preserveStatus</code> reuse</b> ( <code>accessorialChargeService.ts:193–204</code> ) — recompute that reuses the reviewed amount writes a history row implying a fresh computation.        | Audit trail reads "recomputed to \$150" when \$150 was carried over — ambiguity precisely where the ledger must be unambiguous.                              |

## LOW / informational

| ID                 | Finding                                                                                                                                                                                                   |
|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>L1</b> verified | Orphan prod table <code>LoadLead_AdminAudit</code> — zero code references (live table is <code>AdminAuditLog</code> ). Review contents → archive/delete; it predates the TF-managed compliance layer.     |
| <b>L2</b> verified | Unknown <code>/api/*</code> paths return Express's default <i>HTML</i> 404 (framework fingerprint; inconsistent error shape). Add a JSON catch-all after the routers.                                     |
| <b>L3</b> verified | Known flaky test: <code>fieldCrypto</code> GCM tamper flips the last base64 char, which can land in padding bits (no byte change). Deterministic-tamper fix task already open.                            |
| <b>L4</b> verified | The dev Terraform stack has never been applied (no dev EB, 0 dev tables) yet the parity script validates against it. Either apply it, or mark it explicitly as a template and exclude from parity, so the |

|                                        |                                                                                                                                                                                                                                                            |
|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                        | docs match reality.                                                                                                                                                                                                                                        |
| <b>L5</b> <small>agent</small>         | Tour completion in <code>localStorage</code> isn't user-scoped — shared across users/roles on one browser. Prefix keys with <code>userId</code> ; clear on logout.                                                                                         |
| <b>L6</b> <small>agent</small>         | <code>CarrierComplianceView</code> detects the packet-unlock 403 by regex-matching the error <i>message</i> . Return a structured <code>{code:"RELATIONSHIP_REQUIRED"}</code> and match on code.                                                           |
| <b>L7</b> <small>informational</small> | W-9 access log is written <i>before</i> the signed URL is issued — the correct fail-closed direction (an unconsumed log row is noise; an unlogged access would be the real defect). Accepted design; note the false-positive-log caveat for audit tooling. |
| <b>L8</b> <small>informational</small> | FE dollars→cents uses <code>Math.round(parseFloat(x)*100)</code> — the standard conversion; sub-cent inputs are user error, not float corruption. Add 2-decimal input validation and move on.                                                              |

## 5. What the prior rounds' defects look like now

| v2/v3 defect                                                 | Status this round                                                                                                                                                 |
|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HIGH: staging env-var gaps<br>→ silent writes to prod tables | <b>CLOSED</b> — one-knob <code>DYNAMODB_TABLE_PREFIX</code> (49 tables derive), boot guard fails closed, parity script prefix-aware, EB payload 1,511/4096 chars. |
| Missing prod tables for shipped features                     | <b>CLOSED</b> — 0 missing (56/56); compliance tables TF-provisioned with PITR + deletion protection.                                                              |
| Prod TF drift (worm-sink Lambda hash)                        | <b>CLOSED</b> — <code>.DS_Store</code> packaging artifact; excludes added (PR #53); prod plan fully clean.                                                        |
| Deploy smoke too shallow (route-mount only)                  | <b>IMPROVED</b> — W-9 render self-check now gates both deploys; found+fixed a real template-packaging bug that had reached prod.                                  |
| vendor-chunk split blank page (prod FE incident)             | <b>HOLDING</b> — single vendor chunk verified in build and live.                                                                                                  |

## 6. Courses of action

### COA-1 — Close the cheap, sharp edges (this week; 4 small PRs, no migration risk)

| Action                                                                       | Fix sketch                                                                                                                                                    | Addresses |
|------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Rate-limit <code>/w9/render-check</code>                                     | Reuse the existing <code>express-rate-limit</code> config (e.g. 10 req/min/IP) on the route; smoke unaffected.                                                | H4        |
| Clear W-9 form state on success                                              | Reset <code>f</code> (esp. <code>tin</code> ) after the success toast; show a "submitted" summary card instead of the filled form.                            | M1        |
| Schedule COI expiry                                                          | Invoke <code>expireDueCois()</code> on a daily interval at boot (setInterval guarded to one leader) or EventBridge → an admin-token route. Emit count metric. | M3        |
| JSON 404 catch-all for <code>/api/*</code> + 409/410 handling on policy sign | Terminal <code>app.use('/api', ...404 json)</code> ; FE: branch on status for "policy updated — refresh to sign v2" / "no longer available".                  | L2, M2    |

## COA-2 — Correctness under concurrency (next sprint)

| Action                                          | Fix sketch                                                                                                                                                                                                                                | Addresses |
|-------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Atomic supersede                                | Conditional flip ( <code>ConditionExpression: isCurrentVersion = true</code> ) + retry-on-condition-fail loop, or move "current" to a single pointer item per (owner,type) written with <code>attribute_not_exists</code> /version check. | H2        |
| Policy-snapshot repair                          | (a) bounded retry inside <code>finishAccepted</code> ; (b) extend the existing negotiation sweeper to heal ACCEPTED loads missing a policy attachment; (c) metric+alert on snapshot failure.                                              | H1        |
| Global 401 interceptor + structured error codes | One redirect-to-login on 401 in <code>lib/api.ts</code> ; backend errors gain <code>{code}</code> ; FE matches codes not messages.                                                                                                        | M4, L6    |
| Advance↔charge linkage                          | On charge transition to DISPUTED/ADJUSTED, flag any advance referencing it (append an outcome row + notify ops).                                                                                                                          | M6        |
| Refetch-after-accept + config retry             | <code>onAssigned</code> → refetch load; RuntimeConfig retries with backoff before pinning <code>loaded</code> .                                                                                                                           | M5, M8    |

## COA-3 — Scale readiness program (before beta scale-up; the big one)

| Action                             | Fix sketch                                                                                                                                                                                                                                            | Addresses |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| GSI program for hot scans          | Loads by <code>shipperId</code> /by <code>assignedOperatorId</code> (kills the relationship-resolver scan); charges by <code>loadId</code> ; compliance docs by <code>ownerId+type</code> . Staging-first, backfill-free (new GSIs on existing keys). | H3a, H3b  |
| Make the negotiation GSI mandatory | Boot check: fail startup if the <code>loadId</code> GSI is missing (matches the boot-guard philosophy); alert (don't silently scan) on fallback.                                                                                                      | H3c       |
| Notification outbox                | Replace fire-and-forget with an outbox row + retry sweep; ops metric on failures.                                                                                                                                                                     | M7        |
| Load test + alarms                 | k6/artillery against staging at 10x expected beta volume; CloudWatch alarms on DDB throttles + p95 latency before onboarding pushes.                                                                                                                  | H3, ops   |

## COA-4 — Hygiene backlog (opportunistic)

Review + archive `LoadLead_AdminAudit` (L1) · decide the dev stack's fate (L4: apply or demote to documented template) · land the flaky-test fix (L3) · user-scope tour localStorage (L5) · history-row disambiguation for preserved amounts (M9) · 2-decimal money input validation (L8).

## 7. Recommendations (standing practice)

- Promote the staging W-9 E2E to a scheduled synthetic.** The authed submit→mask→access-log flow found a prod-reaching bug the same day it first ran. Run it nightly against staging with a synthetic TIN; alert on failure. Never point it at prod (append-only store, real KMS).
- Keep the "smoke must exercise the real path" bar.** The render self-check pattern (public, canned, non-PII, asserts a hash) generalizes: candidates are policy-render and BOL-render if/when they gain server-side rendering.

3. **Treat scan-fallbacks as incidents, not conveniences.** Any query that can silently degrade to a full scan should fail loudly (boot check or alarm). H3c is the template.
4. **Institutionalize the parity trio** run this round — parity script + untargeted plans (staging/prod) + live mode-diff — as a monthly check or CI cron; all three are fast and already scripted.
5. **Adopt structured error codes now** (small backend change) — three findings this round (M2, M4, L6) trace to FE parsing free-text messages.

## 8. Method & evidence

---

Backend: full vitest (90 files). Frontend: `tsc`, Vite production build, chunk audit, Playwright (46 specs, chromium).  
Infra: `check-table-env-parity.mjs`; untargeted `tofu plan` in staging/prod/dev; AWS live inventory (DynamoDB list-tables diff vs code-required names — 56 required / 60 present / 0 missing / 1 orphan; EB config-settings diff; KMS alias inventory; S3 head-bucket). Live smoke: health, auth guards, beta gate, render-check hash comparison, SPA fallback + cache headers, `/_test` absence. Business logic: two independent read-only audit passes (backend services; frontend guards/API), with every HIGH and headline MEDIUM independently re-verified against source ( `negotiationService.ts:539`, zero `ConditionExpression` s in `complianceDocumentService.ts`, `expireDueCois` call-graph, rate-limiter coverage, FE form-state retention, policy-sign catch block). Findings not independently re-verified are tagged *agent*.

Throwaway staging test data from the 2026-07-09 E2E (account `oo-w9-e2e@loadlead.test`, one synthetic-TIN W-9 row, one access-log row) remains in staging by design; flag for cleanup if staging data hygiene matters.